xss reflected - Sql Injection

Esercizio del Giorno

Argomento: Sfruttamento delle Vulnerabilità XSS e SQL Injection sulla DVWA

Obiettivi:

Configurare il laboratorio virtuale per sfruttare con successo le vulnerabilità XSS e SQL Injection sulla Damn Vulnerable Web Application DVWA.

Configurazione del Laboratorio:

- Configurate il vostro ambiente virtuale in modo che la macchina DVWA sia raggiungibile dalla macchina Kali Linux (l'attaccante).
- Verificate la comunicazione tra le due macchine utilizzando il comando ping.

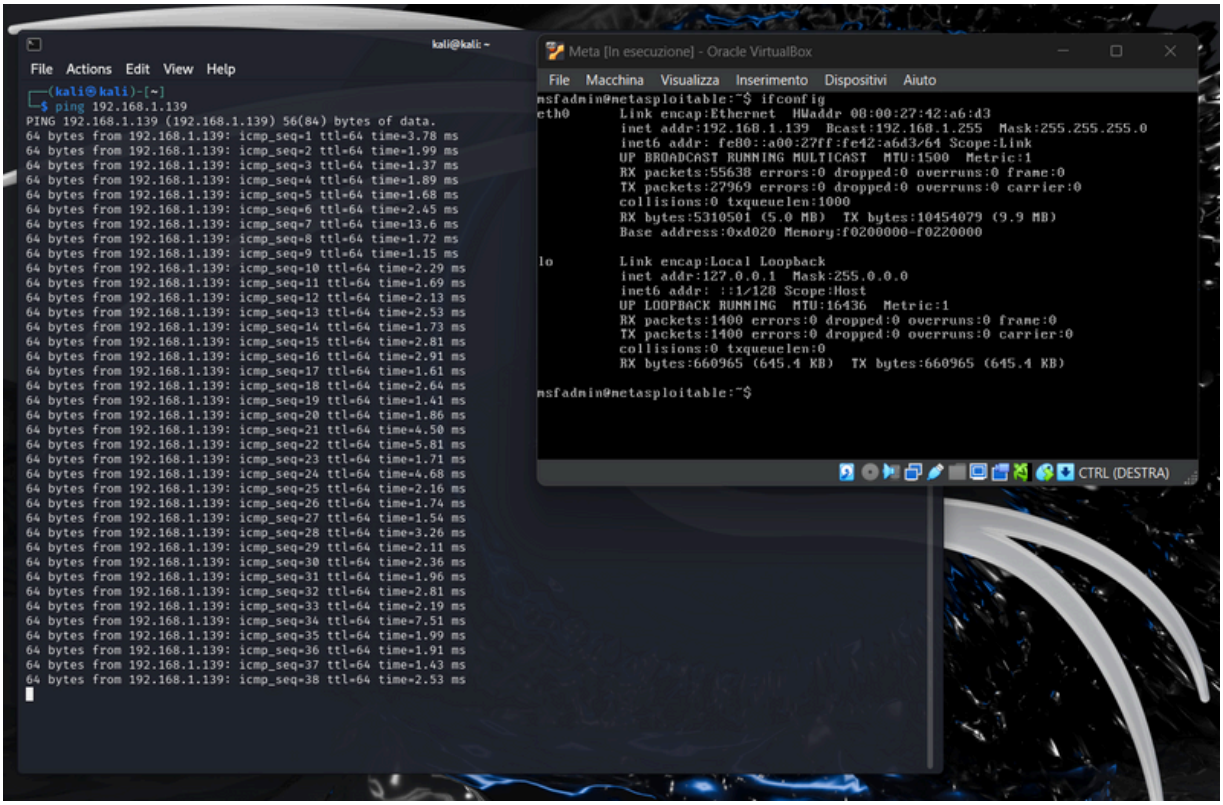
Impostazione della DVWA:

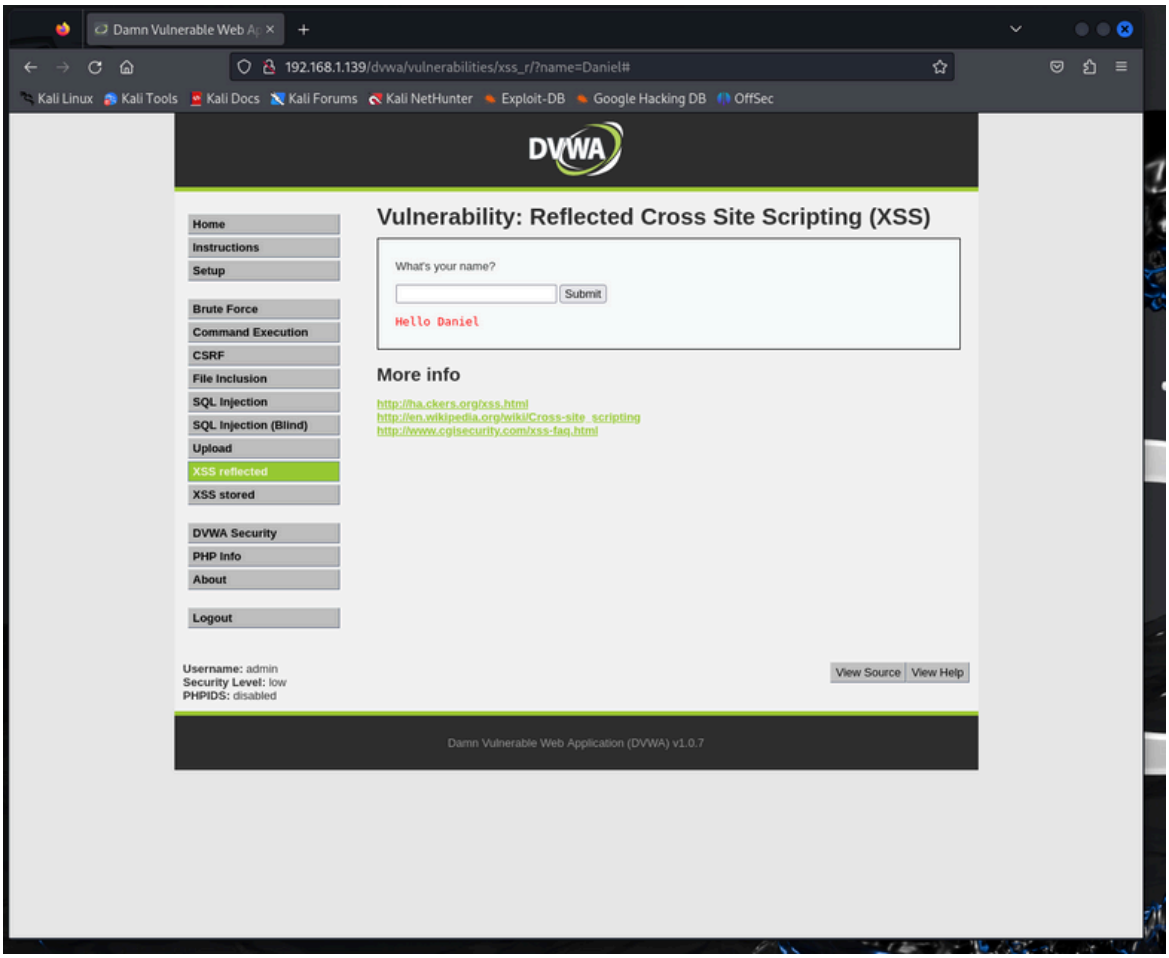
- Accedete alla DVWA dalla macchina Kali Linux tramite il browser.
- Navigate fino alla pagina di configurazione e settate il livello di sicurezza a LOW.

Sfruttamento delle Vulnerabilità:

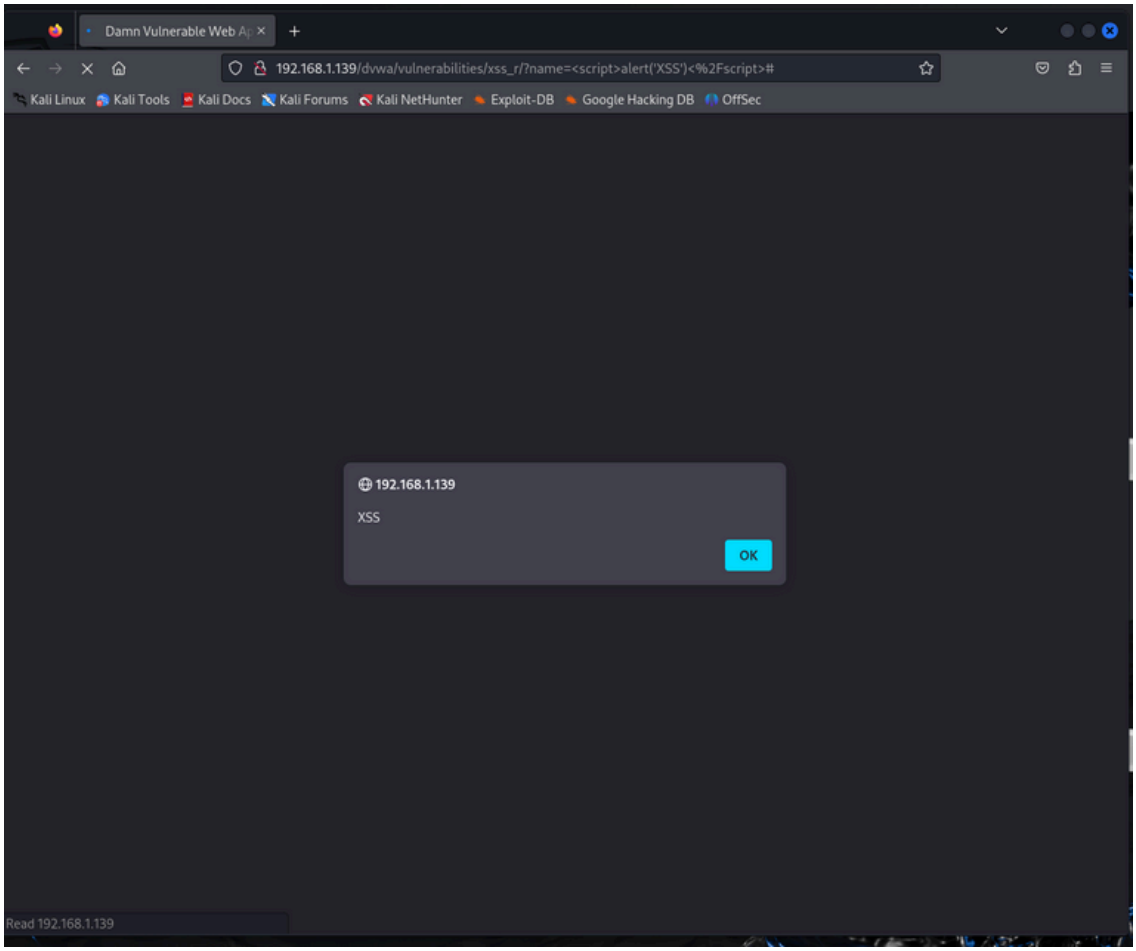
- Scegliete una vulnerabilità XSS reflected e una vulnerabilità SQL Injection (non blind).
- Utilizzate le tecniche viste nella lezione teorica per sfruttare con successo entrambe le vulnerabilità.

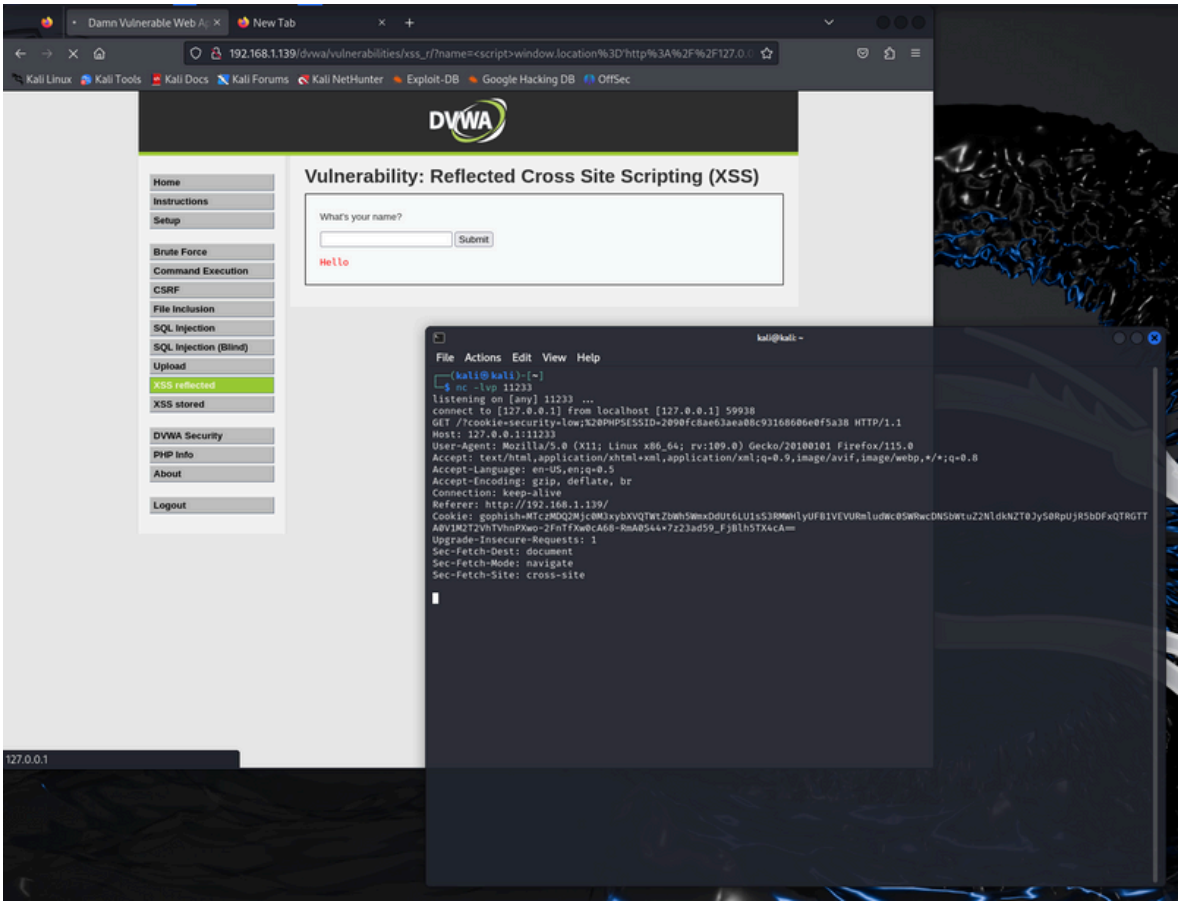
ping + nome


kali@kali: ~
File Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ ping 192.168.1.139
PING 192.168.1.139 (192.168.1.139) 56(84) bytes of data.
64 bytes from 192.168.1.139: icmp_seq=1 ttl=64 time=3.78 ms
64 bytes from 192.168.1.139: icmp_seq=2 ttl=64 time=1.99 ms
64 bytes from 192.168.1.139: icmp_seq=3 ttl=64 time=1.37 ms
64 bytes from 192.168.1.139: icmp_seq=4 ttl=64 time=1.89 ms
64 bytes from 192.168.1.139: icmp_seq=5 ttl=64 time=1.68 ms
64 bytes from 192.168.1.139: icmp_seq=6 ttl=64 time=2.45 ms
64 bytes from 192.168.1.139: icmp_seq=7 ttl=64 time=13.6 ms
64 bytes from 192.168.1.139: icmp_seq=8 ttl=64 time=1.72 ms
64 bytes from 192.168.1.139: icmp_seq=9 ttl=64 time=1.15 ms
64 bytes from 192.168.1.139: icmp_seq=10 ttl=64 time=2.29 ms
64 bytes from 192.168.1.139: icmp_seq=11 ttl=64 time=1.69 ms
64 bytes from 192.168.1.139: icmp_seq=12 ttl=64 time=2.13 ms
64 bytes from 192.168.1.139: icmp_seq=13 ttl=64 time=2.53 ms
64 bytes from 192.168.1.139: icmp_seq=14 ttl=64 time=1.73 ms
64 bytes from 192.168.1.139: icmp_seq=15 ttl=64 time=2.81 ms
64 bytes from 192.168.1.139: icmp_seq=16 ttl=64 time=2.91 ms
64 bytes from 192.168.1.139: icmp_seq=17 ttl=64 time=1.61 ms
64 bytes from 192.168.1.139: icmp_seq=18 ttl=64 time=2.64 ms
64 bytes from 192.168.1.139: icmp_seq=19 ttl=64 time=1.41 ms
64 bytes from 192.168.1.139: icmp_seq=20 ttl=64 time=1.86 ms
64 bytes from 192.168.1.139: icmp_seq=21 ttl=64 time=4.50 ms
64 bytes from 192.168.1.139: icmp_seq=22 ttl=64 time=5.81 ms
64 bytes from 192.168.1.139: icmp_seq=23 ttl=64 time=1.71 ms
64 bytes from 192.168.1.139: icmp_seq=24 ttl=64 time=4.68 ms
64 bytes from 192.168.1.139: icmp_seq=25 ttl=64 time=2.16 ms
64 bytes from 192.168.1.139: icmp_seq=26 ttl=64 time=1.74 ms
64 bytes from 192.168.1.139: icmp_seq=27 ttl=64 time=1.54 ms
64 bytes from 192.168.1.139: icmp_seq=28 ttl=64 time=3.26 ms
64 bytes from 192.168.1.139: icmp_seq=29 ttl=64 time=2.11 ms
64 bytes from 192.168.1.139: icmp_seq=30 ttl=64 time=2.36 ms
64 bytes from 192.168.1.139: icmp_seq=31 ttl=64 time=1.96 ms
64 bytes from 192.168.1.139: icmp_seq=32 ttl=64 time=2.81 ms
64 bytes from 192.168.1.139: icmp_seq=33 ttl=64 time=2.19 ms
64 bytes from 192.168.1.139: icmp_seq=34 ttl=64 time=7.51 ms
64 bytes from 192.168.1.139: icmp_seq=35 ttl=64 time=1.99 ms
64 bytes from 192.168.1.139: icmp_seq=36 ttl=64 time=1.91 ms
64 bytes from 192.168.1.139: icmp_seq=37 ttl=64 time=1.43 ms
64 bytes from 192.168.1.139: icmp_seq=38 ttl=64 time=2.53 ms
Meta [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
msfadmin@metasploitable:~$ ifconfig
eth0 Link encap:Ethernet HWaddr 08:00:27:42:a6:d3
inet addr:192.168.1.139 Bcast:192.168.1.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe42:a6d3/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:55638 errors:0 dropped:0 overruns:0 frame:0
TX packets:27969 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:5310501 (5.0 MB) TX bytes:10454079 (9.9 MB)
Base address:0xd020 Memory:f0200000-f0220000
lo Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:1400 errors:0 dropped:0 overruns:0 frame:0
TX packets:1400 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:660965 (645.4 KB) TX bytes:660965 (645.4 KB)
msfadmin@metasploitable:~$
CTRL (DESTRA)

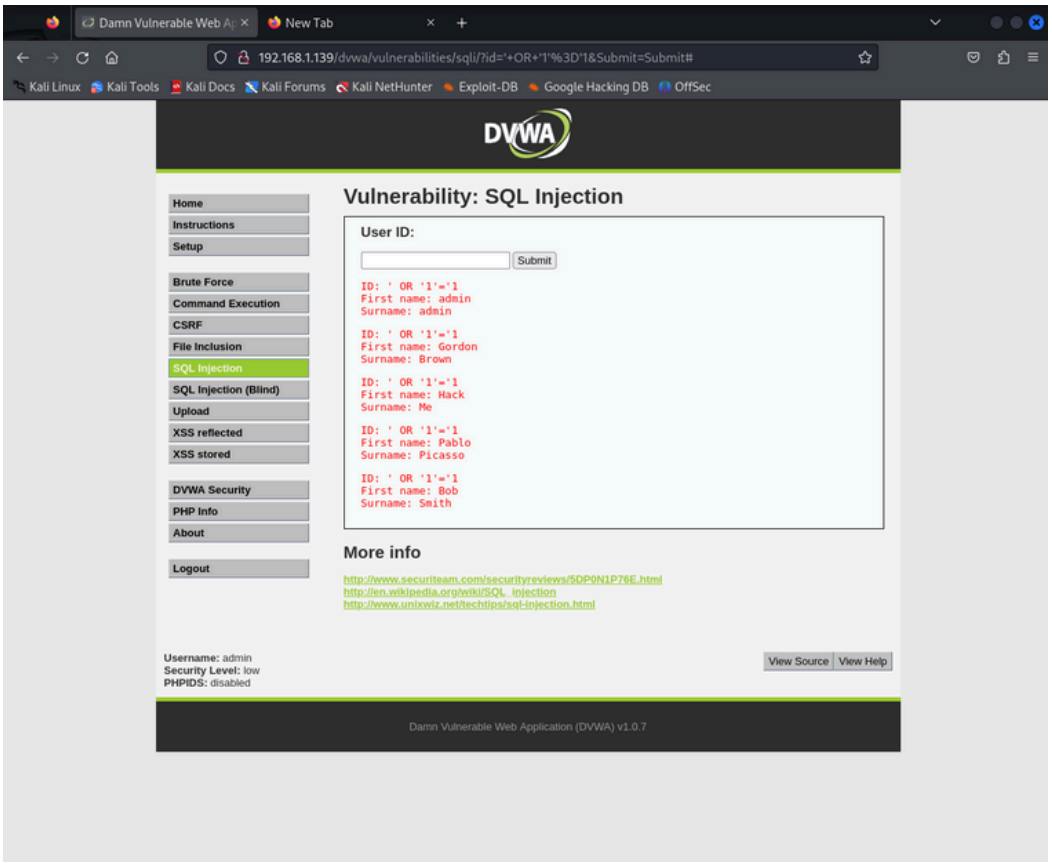

Damn Vulnerable Web Ap
192.168.1.139/dvwa/vulnerabilities/xss_r/?name=Daniel#
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Submit
Hello Daniel
More info
http://ha.ckers.org/xss.html
http://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
Username: admin
Security Level: low
PHPIDS: disabled
View Source View Help
Damn Vulnerable Web Application (DVWA) v1.0.7

pop-up + netcat





sql



Ho effettuato il ping su kali per verificare la comunicazione con meta, a seguire sulla dvwa ho impostato la sicurezza su low, successivamente su xss reflected ho inserito il nome, output “Hello Daniel”. Ho inserito il comando <script>alert('XSS');</script> generato da chatgpt per verificare la vulnerabilità del sito con xss reflected. A richiesta del prof di utilizzare netcat, ho chiesto a chat gpt di generarmi uno script da inserire nella dvwa, e successivamente il comando per mettermi in ascolta sulla porta da me indicata. A seguire per sql injection, ho inserito il comando ' OR '1'='1 per riuscire a bypassare il sistema di autenticazione o visualizzare informazioni aggiuntive. Come da screen ciò a funzionato.